BLAST RADIUS

An agent that runs untrusted code,
measured by what it cannot escape.

blast radius = 0

MEASURED CONTAINMENT FOR REAL AGENT EXECUTION

LIVE https://139.180.147.61.sslip.io/

Team arabeacon · 6 November 2026 · github.com/pham-canh/blast-radius-zero

Agents run code. Nobody measures the box.

- June 2026: agentic tools still exfiltrated API keys and compromised the operator's machine — even when the agent ran inside a sandboxed container (arXiv 2606.24496).
- Security teams get the claim "sandboxed" — not a score, not an artifact, not an audit trail.
- A sandbox you have not attacked is a hope, not a boundary.
- The missing layer is measurement: can the agent show what its payload could not reach?

THE GAP

Containers get the claim. Almost nobody produces the evidence.

That is the product.

A blast radius score, with receipts.

MEASURED BLAST RADIUS

0 **probes escaped**

7 probes · 4 axes · host-side check

PROCESS SECRETS RESOURCES LIFECYCLE

Attestation JSON emitted per run.

- Run the model's code in a disposable container on the Vultr VM.
- Attack that container with 7 probes across 4 containment axes.
- Verify from the host with a canary the payload cannot know.
- Emit a score and a JSON attestation a security team can attach to a release.
- No Docker means DEGRADED — never "contained".

Honest by construction: a probe that never ran cannot pass.

Live on Vultr. Attack it yourself.

https://139.180.147.61.sslip.io/

Public HTTPS · /healthz reports docker=true and the live model

1. **Run the default CSV task.**
   Read the model-written code and the real stdout.

2. **Open "Measure blast radius".**
   Press re-measure; the suite attacks the live VM.

3. **Watch rm_rf fail to escape.**
   Host canary stays intact; blast radius = 0.



Live run: model-written code, real stdout, all four axes CONTAINED.

One loop: generate → execute → repair → measure.

TASK

a real coding task
+ stdin

→

VULTR INFERENCE

deepseek-v4.1-flash-1017
code + repair from stderr

→

CONTAINER

docker run, disposable
no net · read-only · non-root

→

PROBES

7 attacks, 4 axes
host-side canary check

→

SCORE

blast radius + JSON
attestation

Self-healing is real, not a slide:

a failed run sends the container's actual stderr back to the model; the next attempt runs again.

Every Vultr pillar is load-bearing: VM = execution host · Inference = code + repair · container = boundary.

Verified on the Vultr VM. 6 Nov 2026.

```
$ python3 src/main.py --probe

blast radius = 0  ->  BLAST RADIUS ZERO
[runtime: container]

process_isolation     CONTAINED  1/1
secret_hygiene        CONTAINED  2/2
resource_limits       CONTAINED  2/2
lifecycle_discipline  CONTAINED  2/2

[CONTAINED] rm_rf     host canary intact
[CONTAINED] net_egress egress blocked: OSError
[CONTAINED] residue   nothing survived
```

- 44/44 tests pass.
- Real model call: deepseek-v4.1-flash-1017 via Vultr Serverless Inference.
- Model-written code ran in a container; stdout = 11.67.
- Attestation: vultr_vm_backend=true, canary intact, blast radius 0.
- /healthz confirms Docker, provider and model.

Full command output and environment: docs/EVIDENCE.md · raw record: docs/attestation.example.json

Vultr is the demo, not a logo.

VULTR VM

Hosts the app and spawns every disposable container. Remove it and there is nowhere to execute.

SERVERLESS INFERENCE

Writes the code, reads the real stderr, repairs it. Remove it and both agent loops stop.

SANDBOX

docker run with no network, read-only root, cap-drop ALL, non-root, memory/pids/CPU caps.

Every sandbox flag is pinned by a test. The boundary is the product.

`One-command bootstrap · 2 vCPU / 4 GB · HTTPS on <ip>.sslip.io · $20/mo`

The agent security budget is the market.

$8B

AI systems security by 2030

Dell'Oro Group, 2026 (analyst forecast)

- Every team shipping an agent needs a containment answer for security review.
- Buyers: platform teams, AppSec and compliance — the people who sign off releases.
- Bottom-up SAM: 10k agent teams × $10k/yr = $100M (assumption to validate).
- Wedge: CI attestation; expand into runtime policy and audit.

Why now

Agent adoption is outrunning the evidence layer. Containment is becoming a line item, not a paragraph in a design doc. The first credible score becomes the default.

Open-source wedge. SaaS + meter.

OPEN SOURCE

Free

CLI + probe suite

Adoption and trust

TEAM

$99 / mo

per workspace

History, policies, audit export

METERED API

$0.01 / run

for platforms

Attestation at execution time

Go to market

GitHub Action → Vultr Marketplace → agent-platform partnerships.

Land with the open CLI; expand with audit history and per-run attestations.

Team arabeacon.

Built the loop

Canh Pham
agent loop · inference · Vultr deploy

Abdul Ahad
backend · sandboxing

Amna Yaqoob
product · coordination

Next 3 milestones

1. Hosted attestation API
2. GitHub Action for CI
3. Policy packs for LangGraph / CrewAI

ASK

Vultr credits for the next measurement runs · design partners with live agents · a security review.

`Live: https://139.180.147.61.sslip.io/` · `Repo: github.com/pham-canh/blast-radius-zero`